

INCIDENT HANDLER'S JOURNAL

Suspicious Login and Phishing Investigation

KifaruCart Global Ltd.

Journal control and metadata

Attribute	Details
Journal entry reference	Entry 001 (Incident Ref: INC-2026-0822-0051)
Incident date	August 22, 2026 (08:41 - 11:20 EAT)
Organization	KifaruCart Global Ltd.
Incident classification	Business Email Compromise (BEC) / Account Takeover / Internal Phishing
Lead handler	SOC Analyst / Incident Handler
Target user account	finance.assistant@kifarucart.example
Impacted environment	Microsoft 365 / Exchange Online / Cloud Infrastructure
Incident severity	High
Current status	Contained / active 72-hour post-incident recovery and monitoring

Incident summary

This incident handler journal documents a suspicious login and phishing investigation involving the finance assistant account at KifaruCart Global Ltd. The account was accessed from an unusual source IP address while multi-factor authentication was not enforced. Shortly after the login, the attacker created mailbox forwarding rules and sent an internal phishing message to 23 employees.

The incident was classified as a confirmed Business Email Compromise and account takeover. Containment actions were completed quickly by disabling the account, revoking active sessions, removing malicious rules, purging phishing messages, and enforcing MFA on the affected account. Continued 72-hour monitoring remains in progress pending endpoint verification for the one employee who opened the phishing attachment.

The 5 W's

Question	Journal response
Who	finance.assistant@kifarucart.example, a finance assistant handling payment confirmations, vendor invoices, and customer refunds.
What	Successful unauthorized login from an anomalous foreign location, malicious inbox forwarding rules, and internal phishing targeting 23 employees.

When	August 22, 2026, between 08:41 EAT and 10:30 EAT.
Where	Microsoft 365 tenant, Exchange Online tenant, and internal employee mailboxes.
Why	Likely credential theft caused by external phishing or password reuse. The attacker attempted to establish email exfiltration and internal credential harvesting.

Key incident profile and evidence

Incident attributes

Attribute	Observed value	Risk interpretation
Detection source	M365 sign-in logs and user phishing report	Dual-channel confirmation from system telemetry and a human report.
Anomalous source IP	198.51.100.88	Unverified foreign IP address from documentation range.
Normal access IP	102.214.88.19 (Nairobi, Kenya)	Established baseline location for the user.
Authentication mechanism	Single-factor authentication (password only)	Critical weakness; no MFA challenge was issued.
MFA status	Not enforced	Enabled exploitation using stolen credentials.
Business impact	Potential payment record exposure and lateral phishing	Moderate-to-high confidentiality impact.

Sign-in activity audit

Time (EAT)	Source IP	Location	Result	Security note
08:12	102.214.88.19	Nairobi, KE	Success	Normal baseline activity.
08:41	198.51.100.88	Unusual region	Success	Suspicious foreign login.
08:43	198.51.100.88	Unusual region	Success	Secondary authentication check-in.
09:02	102.214.88.19	Nairobi, KE	Success	Legitimate user session; user later reported being unaware of the breach.

Mailbox activity audit

Time (EAT)	Action observed	Action details	Threat purpose
08:44	Inbox rule created	Forward all messages containing "invoice" externally.	Automated data exfiltration.
08:46	Inbox rule created	Mark forwarded messages as "read" automatically.	Defense evasion / hiding footprints.
08:52	Outbound email sent	Subject: Updated payment schedule - action required.	Internal spear phishing.
08:55	Message distribution	Message delivered to 23 internal staff recipients.	Lateral movement attempt.
09:10	Attachment opened	Recipient executed Payment_Schedule_Update.html.	Potential secondary compromise.

Suspicious email sample

Field	Value
Header sender	finance.assistant@kifarucart.example
Subject line	Updated payment schedule - action required
Attachment name	Payment_Schedule_Update.html
Embedded URL target	hxxp://kifaru-payments-login.example/login
Reporting mechanism	Flagged manually by HR staff member at 09:18 EAT

Master incident chronology

Time (EAT)	Event
08:41	Unauthorized Microsoft 365 login from foreign IP address 198.51.100.88.
08:44	Malicious inbox forwarding rule created for messages containing "invoice".
08:55	Internal phishing email broadcast to 23 employees.
09:10	Phishing HTML attachment opened by one internal user.
09:18	HR staff member reports phishing email; SOC investigation begins.
09:32	Affected account disabled and active Microsoft 365 sessions revoked.
09:48	Forwarding rules deleted and phishing emails purged from mailboxes.
10:30	Account password reset and mandatory MFA enforced.

Incident handler journal entries

Entry 001: Initial alert review

Date / Time	August 22, 2026, 09:18 EAT
Action taken	Reviewed user-submitted phishing alert forwarded by an HR employee.
Tool(s) used	User report / phishing report workflow
Observations	HR reported an urgent message from the finance assistant requesting staff to download an attached payment schedule.
Analysis	High risk of internal credential harvesting due to urgency keywords and an HTML attachment.
Next steps	Conduct Exchange message trace and review user sign-in logs.

Entry 002: Sign-in log analysis

Date / Time	August 22, 2026, 09:25 EAT
Action taken	Audited Microsoft Entra ID sign-in logs for finance.assistant@kifarucart.example.
Tool(s) used	Microsoft Entra ID sign-in logs
Observations	Successful login recorded at 08:41 EAT from 198.51.100.88 outside Kenya. Single-factor password authentication was used; MFA was absent.
Analysis	High-confidence account takeover confirmed.
Next steps	Pivot to Exchange mailbox audit logs to verify post-exploitation actions.

Entry 003: Mailbox audit review

Date / Time	August 22, 2026, 09:28 EAT
-------------	----------------------------

Action taken	Queried Exchange Online mailbox audit trail.
Tool(s) used	Exchange Online mailbox audit logs
Observations	Two automated rules were added at 08:44 and 08:46 EAT: forwarding invoice communications externally and auto-marking messages as read.
Analysis	Classic Business Email Compromise pattern designed to exfiltrate financial data while evading user detection.
Next steps	Initiate immediate account containment.

Entry 004: Containment

Date / Time	August 22, 2026, 09:32 EAT
Action taken	Temporarily disabled the account and revoked all active OAuth refresh tokens and sessions.
Tool(s) used	Microsoft 365 admin center / identity administration
Observations	Attacker active session was terminated.
Analysis	Immediate threat vectors were cut off and exfiltration was paused.
Next steps	Purge malicious rules and remove internal phishing emails.

Entry 005: Email environment cleanup

Date / Time	August 22, 2026, 09:48 EAT
Action taken	Removed malicious inbox forwarding rules via PowerShell and initiated a compliance purge across 23 target mailboxes.
Tool(s) used	Exchange Online PowerShell / compliance search
Observations	All 23 phishing copies were deleted; one employee opened Payment_Schedule_Update.html at 09:10 EAT.
Analysis	Phishing spread was contained, but the exposed recipient's workstation requires isolated triage.
Next steps	Assess cloud storage access and initiate account recovery.

Entry 006: Scope and impact assessment

Date / Time	August 22, 2026, 10:05 EAT
Action taken	Audited OneDrive/SharePoint access logs and outbound email forwarding volume.
Tool(s) used	OneDrive/SharePoint audit logs / email forwarding logs
Observations	No mass cloud file downloads were detected; invoice emails received between 08:44 and 09:32 EAT were forwarded to an external actor address.
Analysis	Moderate-to-high confidentiality impact regarding financial records; no administrative access observed.

Next steps	Provision hardened account credentials for the user.
-------------------	--

Entry 007: Account recovery and hardening

Date / Time	August 22, 2026, 10:30 EAT
Action taken	Performed identity verification, reset password, and enforced mandatory Microsoft Authenticator MFA.
Tool(s) used	Identity administration / MFA enrollment
Observations	Account was restored to the user with full security controls active.
Analysis	Recovery complete; account fortified against single-factor password attacks.
Next steps	Conduct post-incident briefing and post-mortem.

Entry 008: Lessons learned and post-mortem

Date / Time	August 22, 2026, 11:20 EAT
Action taken	Briefed management and updated incident response documentation.
Tool(s) used	Post-incident review / incident register
Observations	Incident root cause traced to credential theft enabled by lack of MFA enforcement.
Analysis	MFA and auto-forwarding restrictions would have prevented or reduced the impact of initial access and exfiltration.
Next steps	Implement enterprise-wide conditional access policies.

Action plan matrix

Containment and eradication

Priority	Action item	Responsible party	Status	Operational goal
P1	Disable compromised user account	Identity Admin	Completed	Cease unauthorized access.
P1	Revoke Microsoft 365 active user sessions	Identity Admin	Completed	Kill active attacker OAuth tokens.
P1	Delete malicious forwarding rules	Email Admin	Completed	Close exfiltration channel.
P1	Purge internal phishing messages	Exchange Admin	Completed	Remove malicious emails from 23 mailboxes.
P1	Block phishing URL at firewall/DNS	Network Team	Completed	Block credential-harvest domain.
P2	Perform endpoint triage on exposed user	IT Support	In progress	Verify if HTML payload executed malware.

Recovery action items

Recovery action item	Responsible party	Status
Reset user password to complex standard	Identity Admin	Completed
Enforce mandatory multi-factor authentication (MFA)	IT Admin	Completed
Verify user identity in person before credential handover	IT Support	Completed
Notify exposed internal recipients and send cautionary guidance	SOC / HR	Completed
Audit finance department payment and refund logs for anomalies	Finance Manager	In progress
Log incident details in central security register	Lead SOC Analyst	Completed

Lessons learned and remediation roadmap

Improvement area	Root cause addressed	Remediation action	Owner	Window
Company-wide MFA enforcement	Single-factor password vulnerability	Enforce MFA across 100% of tenant accounts via Conditional Access.	IT Manager	0-30 days
Disable external auto-forwarding	Data exfiltration via mailbox rules	Disable external automated forwarding at Exchange transport level.	Email Admin	0-30 days
Mailbox rule creation alerts	Stealthy attacker persistence	Configure SIEM alerts for new forwarding or redirect inbox rules.	SOC Lead	0-30 days
Impossible travel / geo-blocking	Anomalous authentication	Block authentication attempts originating from non-business regions.	IT Manager	0-30 days
Phishing awareness training	User vulnerability to HTML attachments	Conduct quarterly simulated phishing campaigns for all departments.	HR / SOC	30-60 days

Final incident summary and status

The Business Email Compromise incident involving `finance.assistant@kifarucart.example` is formally contained. The threat actor gained access using stolen credentials because MFA was not enforced, created data exfiltration rules, and broadcast an internal phishing campaign. Active containment cut off access within 47 minutes of user reporting.

The account is fully recovered with mandatory MFA enabled. Active 72-hour telemetry monitoring is still in progress, and final ticket closure is pending endpoint verification for the single exposed staff member who opened the suspicious HTML attachment.

Status field	Current status
Incident classification	Confirmed Business Email Compromise / Account Takeover
Severity	High
Containment status	Completed
Recovery status	Completed for affected account; endpoint verification in progress
Monitoring status	72-hour post-incident monitoring active
Closure condition	Close after endpoint verification and monitoring show no recurrence